

ЛР 5

Недостатки в Python-коде и механизмы безопасности Django

Python

Django security

Максимум 10 баллов

Кратко о задании

Цель:

Научиться находить распространенные недостатки в python-коде. Познакомиться с механизмами безопасности в django.

Описание / пошаговая инструкция выполнения домашнего задания

Часть I.

Для приведенного фрагмента кода необходимо указать его недостаток, а также написать рекомендации по его устранению. Например, у такого кода:

Пример кода

```
with connection.cursor() as cursor:  
    cursor.execute(""" SELECT admin FROM users WHERE username = '%s' """ % username)
```

недостаток заключается в том, что введенные пользователем данные не проверяются и "as is" передаются в базу данных.

В качестве мер противодействия можно либо корректно обрабатывать пользовательский ввод, либо использовать библиотеки, которые экранируют все опасные символы, что является более предпочтительным вариантов.

Часть I - фрагменты кода

Для каждого фрагмента нужно указать недостаток и рекомендации по устранению.

Фрагмент кода 1

```
#!/usr/bin/env python3
from flask import Flask

from mod_api import mod_api

app = Flask('vuln_app')
app.config['SECRET_KEY'] = 'F0cUzh8BgYJSLXAU8qDmClM0dE8GJTpsiyVEl3BCqQMCABp1U$f%'

app.register_blueprint(mod_api, url_prefix='/api')
```

Фрагмент кода 2

```
from flask_wtf import Form
from wtforms import TextField

class LoginForm(Form):
    username = TextField('username')
    password = TextField('password')
```

Фрагмент кода 3

```
def post(self):
    username = self.get_argument('username')
    password = self.get_argument('password').encode('utf-8')
    email = self.get_argument('mail')

    try:
        username = username.lower()
        email = email.strip().lower()
        user = User({'username': username, 'password': password, 'email': email, 'date_joined':
curtime()})
        user.validate()
        save_user(self.db_conn, user)
    except Exception, e:
        return self.render_template("success_create.html")
```

Часть II - модель безопасности Django

Изучить модель безопасности django. Ответить на вопросы.

№	Вопрос
1	Какие наиболее распространенные атаки предотвращает django?
2	Описать, как устроено управление пользовательскими сессиями в django

Критерии оценки

Часть I	Баллы
За каждый правильно найденный недостаток в одном фрагменте кода	2 балла

Часть II	Баллы
Вопрос 1	1 балл
Вопрос 2	3 балла

Итог	Значение
Минимальный проходной балл	3 балла
Максимальное количество баллов за ДЗ	10

Формат ответа

Ответ по части I - указать недостаток каждого фрагмента кода и рекомендации по устранению.

Ответ по части II - ответить на два вопроса по модели безопасности django.